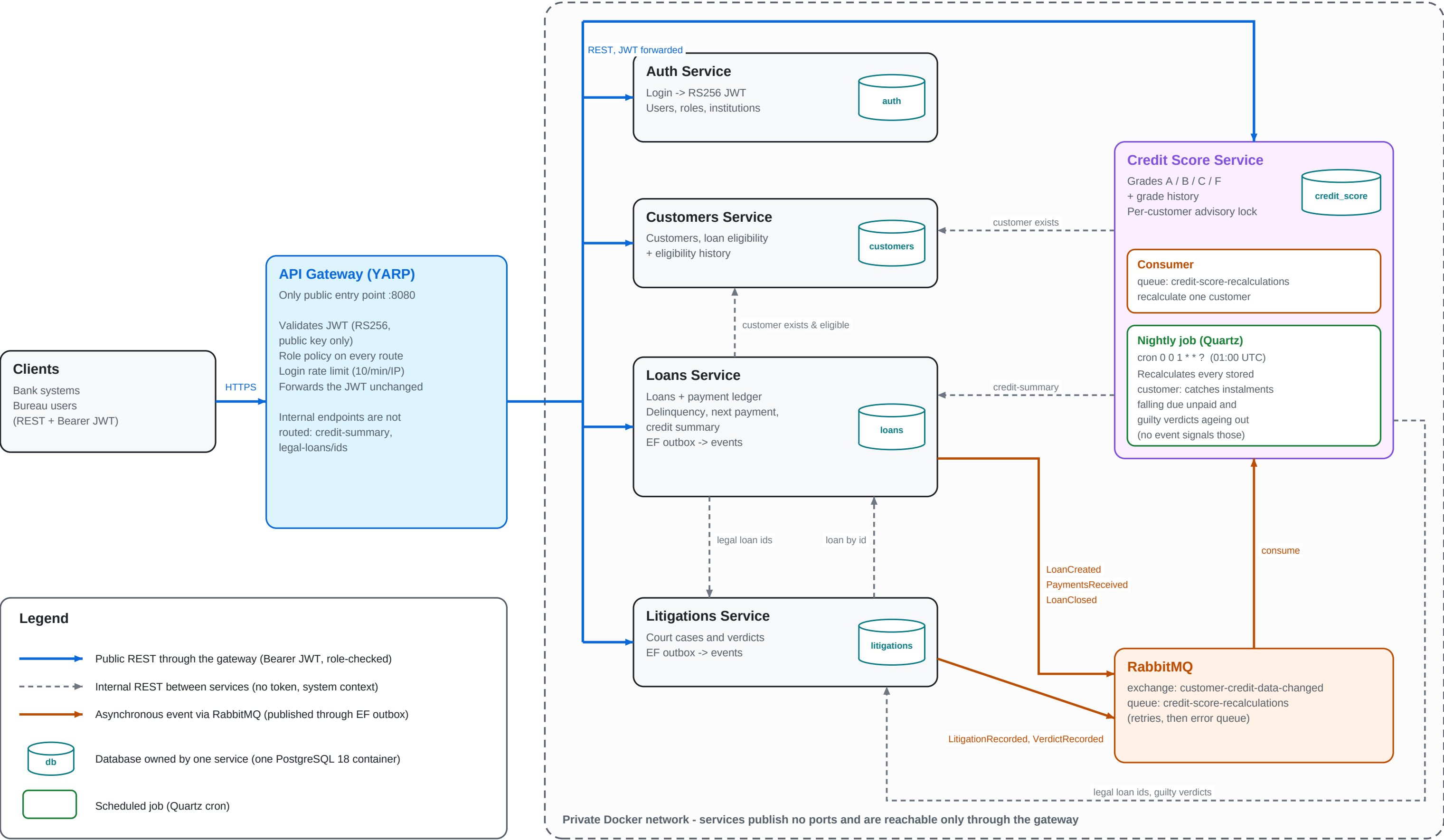


Credit Information System - Architecture

.NET 10 microservices behind a YARP API gateway, PostgreSQL (database per service), RabbitMQ events with a transactional outbox



Credit Information System - Architecture Decisions

Assumptions made where the brief is silent, the key design decision, and known limitations

Assumptions

Loans and payments

- A loan's terms are **fixed and provided by the bank**: instalment amount, payment frequency, tenor (the number of instalments) and first due date. The instalment schedule is derived from them, never stored.
- **amount** is the money lent, without interest. **rate** is informational only and never used in calculations. A down payment is outside the loan.
- Only **instalment loans** are in scope. Revolving credit (credit cards, overdrafts) is not.
- Payments settle the **oldest unpaid instalment first**. Overpayments are accepted: the bureau records what the bank reports.

Delinquency

- A delinquency is a **past-due instalment that is still not fully paid**, counted per instalment across all of a customer's loans, closed ones included.
- An instalment is late from the **day after** its due date.
- A loan can be **closed at any time**: early, not fully paid, or with delinquencies. Its unpaid instalments keep counting against the credit grade.

Litigation

- A loan is **in a legal state** while any of its cases is **PENDING** or **GUILTY**. An **INNOCENT** verdict clears it.
- A loan can have several cases, but **at most one GUILTY** verdict, and no new cases once it has one.
- A verdict is recorded **once**. Appeals are out of scope.

Access

- The **bureau is an institution too**. Bank users see other banks' loans with the bank hidden (**OTHER_BANKS**) and can only change their own bank's loans, payments and cases.
- New customers are **eligible by default**. Blocking is a bureau-admin action, recorded with a reason and who made it.

Design Decision

- **Only the API gateway validates JWTs** (RS256, public key only). Services read the forwarded token without re-validating it. Internal service-to-service calls carry no token and run as the system.

Limitations

- **No refresh tokens**, only 60-minute access tokens. A role change takes effect only when the user's current token expires, and there is no logout or token revocation.
- **Services trust the gateway**. If something gets inside the private network, a forged token would be accepted. Production should add mTLS or per-service token validation.
- **The credit grade forgets past late payments** once they are paid, unlike real credit bureaus, which keep them on record for years.